

GhostToken

Exploiting Google's OAuth Implementation



Today's (Ghost) Story

Invisible apps having access to your account

GET /me HTTP/1.1

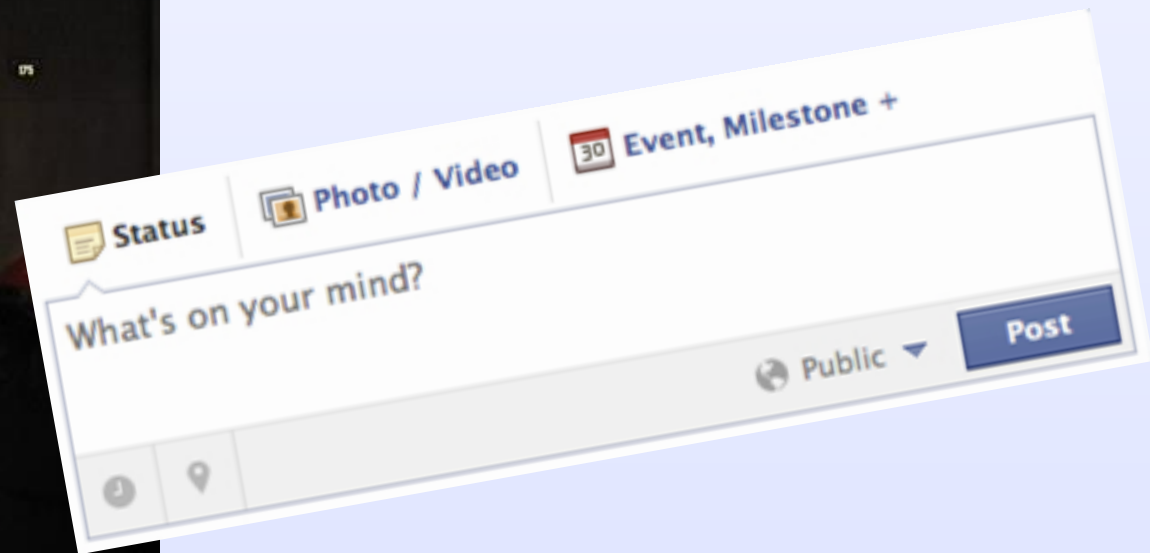
- A decade of hacking
- Hacked vehicle computers on a daily basis
- Broke Pokémon Go's anti-cheating system in 2016
- M.Sc. in computer science
- Senior Security Researcher at Astrix Security



@TalSkverer, [linkedin.com/in/reverser/](https://www.linkedin.com/in/reverser/)

Our story begins in 2007

Before OAuth existed...



1 The First to Buy the iPhone, Apple Gazette <https://www.applegazette.com/iphone/the-first-to-buy-the-iphone/>

2 Facebook Pages, My Second Million <http://www.mysecondmillion.com/facebook-pages-add-content-timeline/>

Before OAuth Existed...



Ann

FindMoreContacts

 **See if more friends have joined Facebook** Close

Find friends in your email address book who are already on Facebook

Your Email:

Email Password:

Find Friends

We won't store your login info or contact anyone without your permission

Don't see your email in the list? If you use AIM, check your AIM Buddy List.

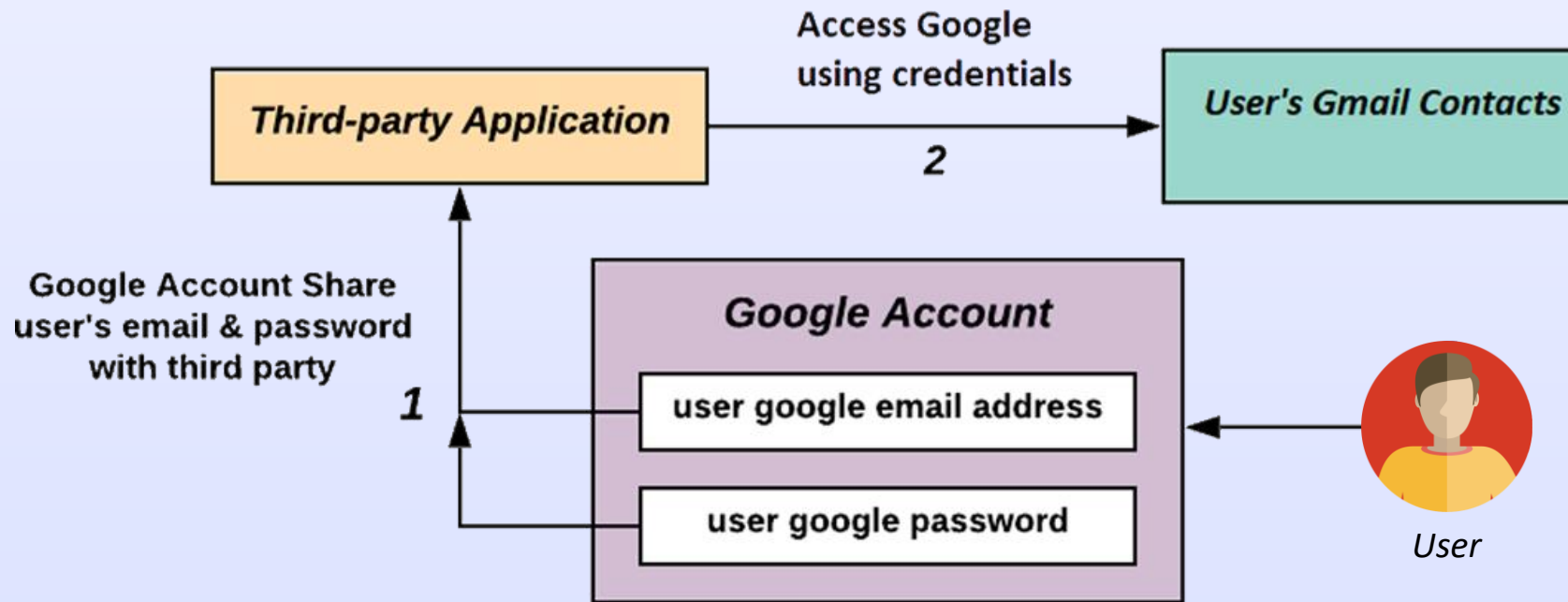
- select...
- hotmail.com
- yahoo.com
- ✓ gmail.com
- aol.com
- msn.com
- hotmail.co.uk
- yahoo.co.uk
- yahoo.ca
- live.com
- comcast.net

Wait...What?

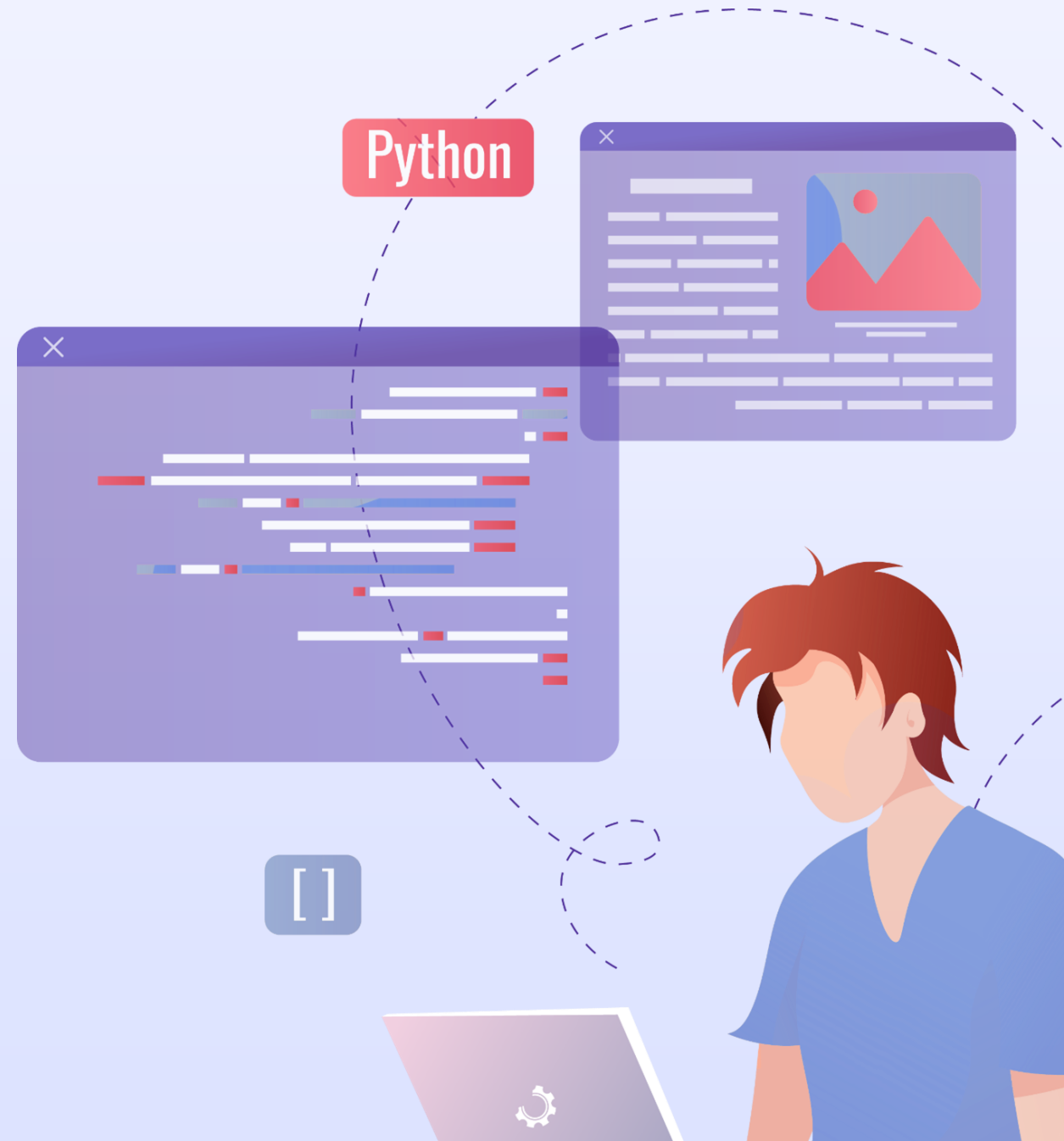


Wait...What?

World without OAuth



1. App got full access to Google account
2. User can remove the app only with password change
3. Same password used across services



The Inception of OAuth



“

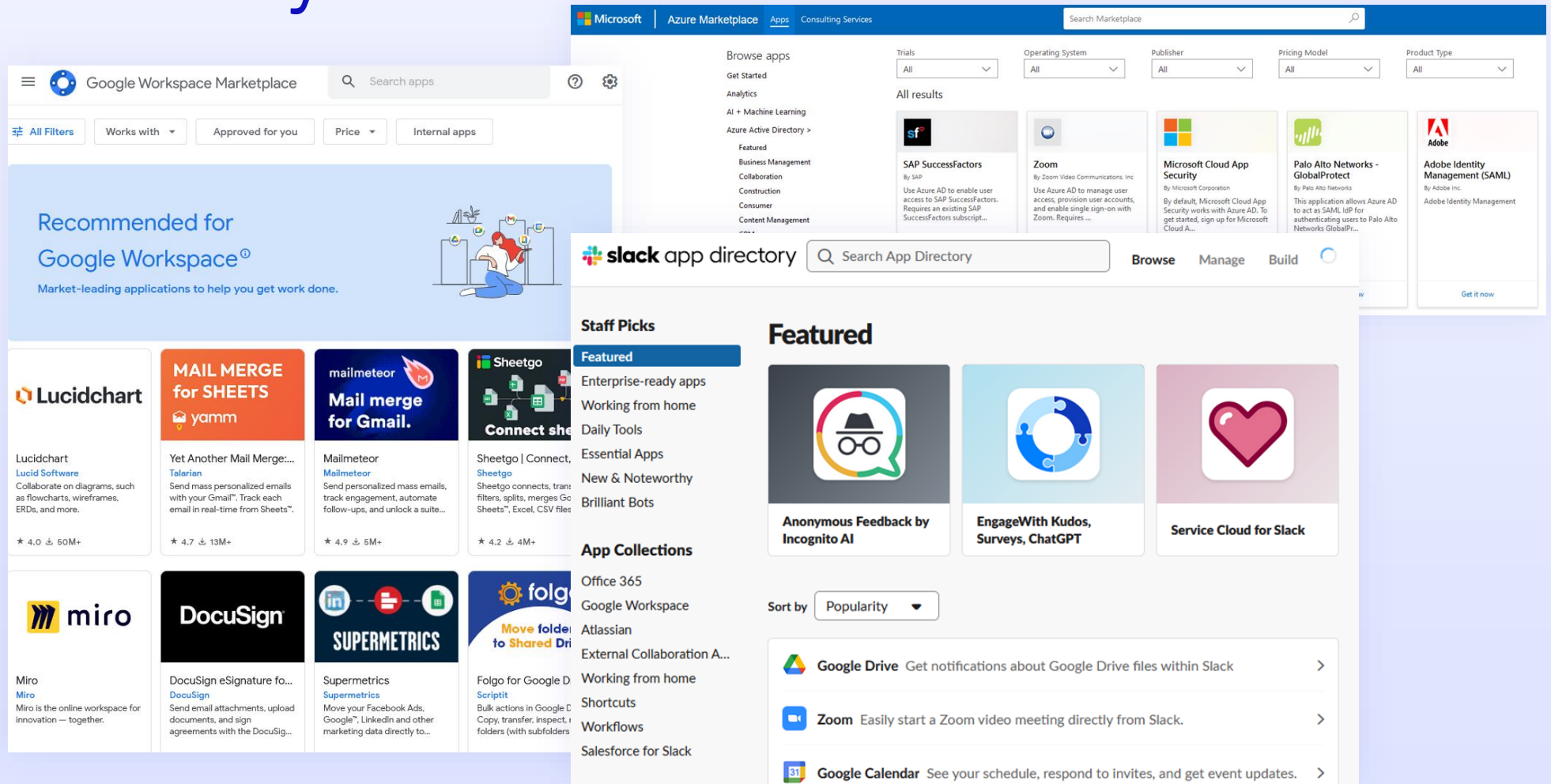
Luxury cars today come with a valet key: it's a special key that... will not allow the car to drive more than a mile or two. Some valet keys will not open the trunk... others will block access to your onboard cell phone address book.

... The idea is very clever: you give someone limited access to your car with a special key, while using your regular key to unlock everything.

”

Present Day

OAuth 2.0 is everywhere



1 Google Workspace Marketplace, Google <https://workspace.google.com/marketplace>

2 The App Directory, Slack <https://slack.com/apps/category/At0EFWTR6D-featured>

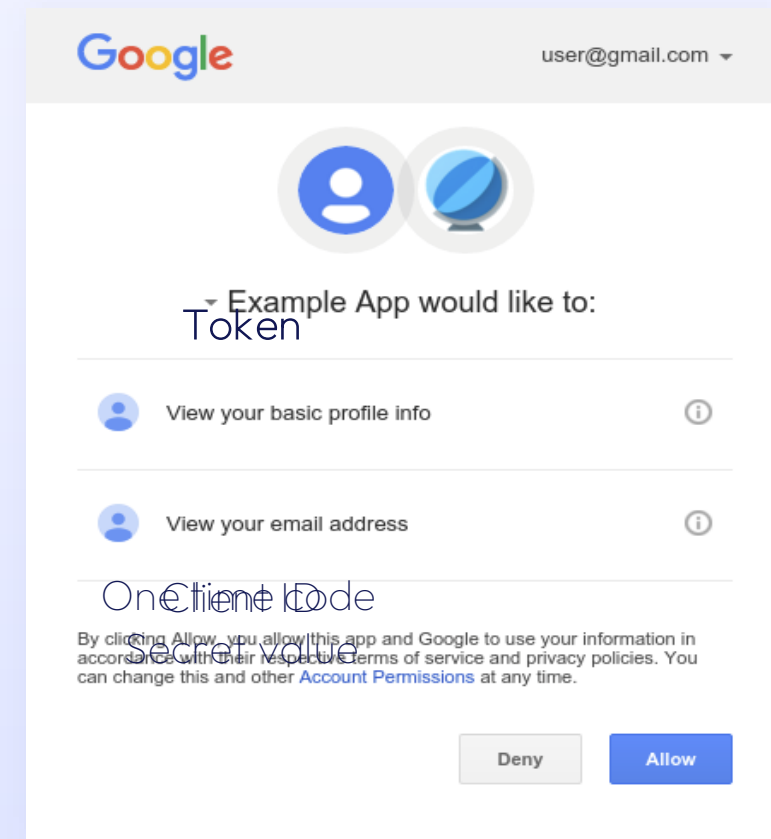
3 The Azure Marketplace, Microsoft <https://azuremarketplace.microsoft.com/en-us/marketplace/apps/category/azure-active-directory-apps>

The OAuth 2.0 Framework Puzzle



Secret value

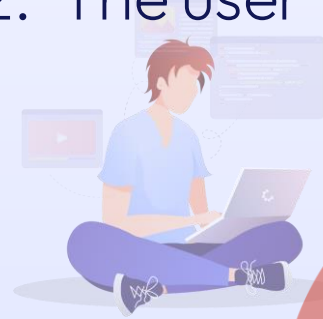
Client ID
Permission List



User gets consent screen

OAuth 2.0: The Missing Pieces

1. App registration process
2. The user's app management features



Google

Client ID
Secret value

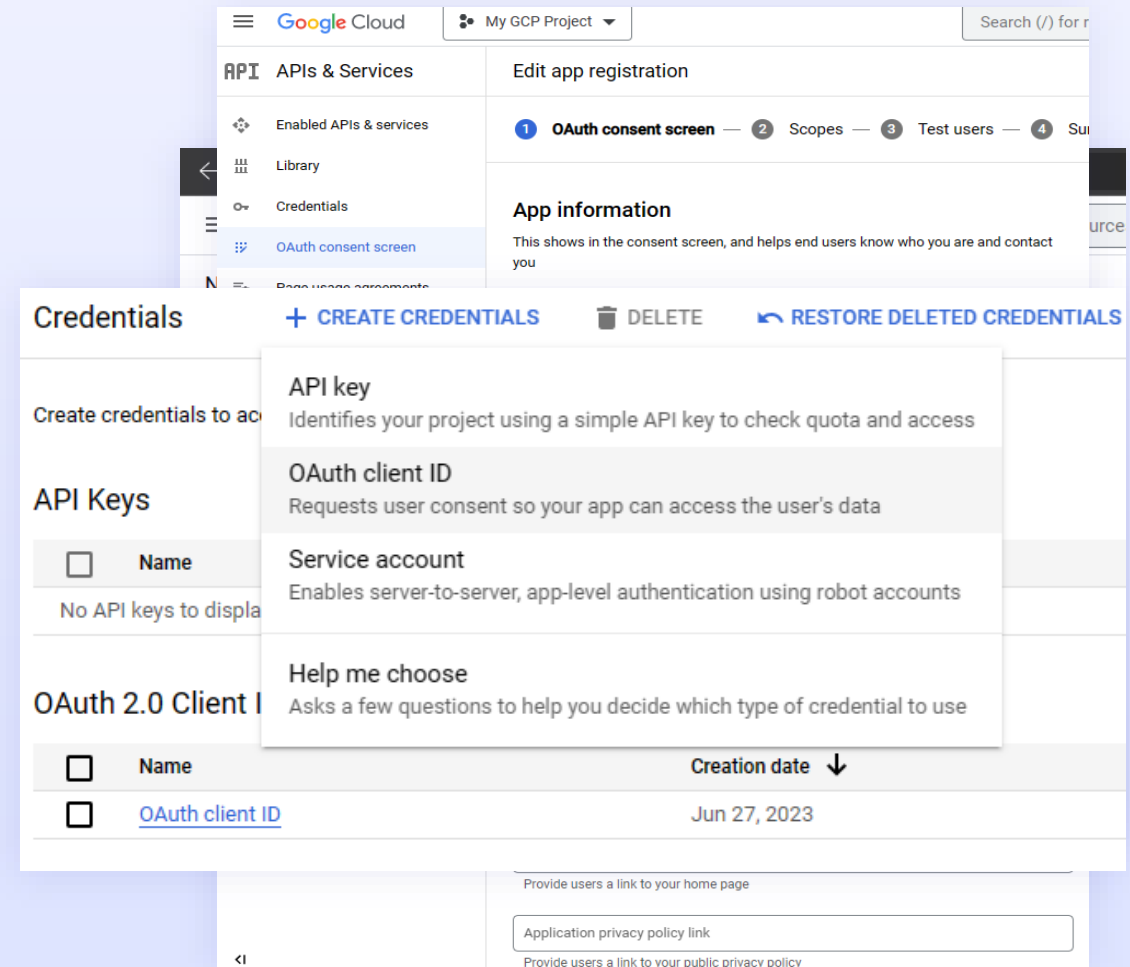
When registering a client, the client developer SHALL:

- o specify the client type as described in [Section 2.1](#),
- o provide its client redirection URIs as described in [Section 3.1.2](#), and
- o include any other information required by the authorization server (e.g., application name, website, description, logo image, the acceptance of legal terms).

Missing piece #1:

Google's App Registration Process

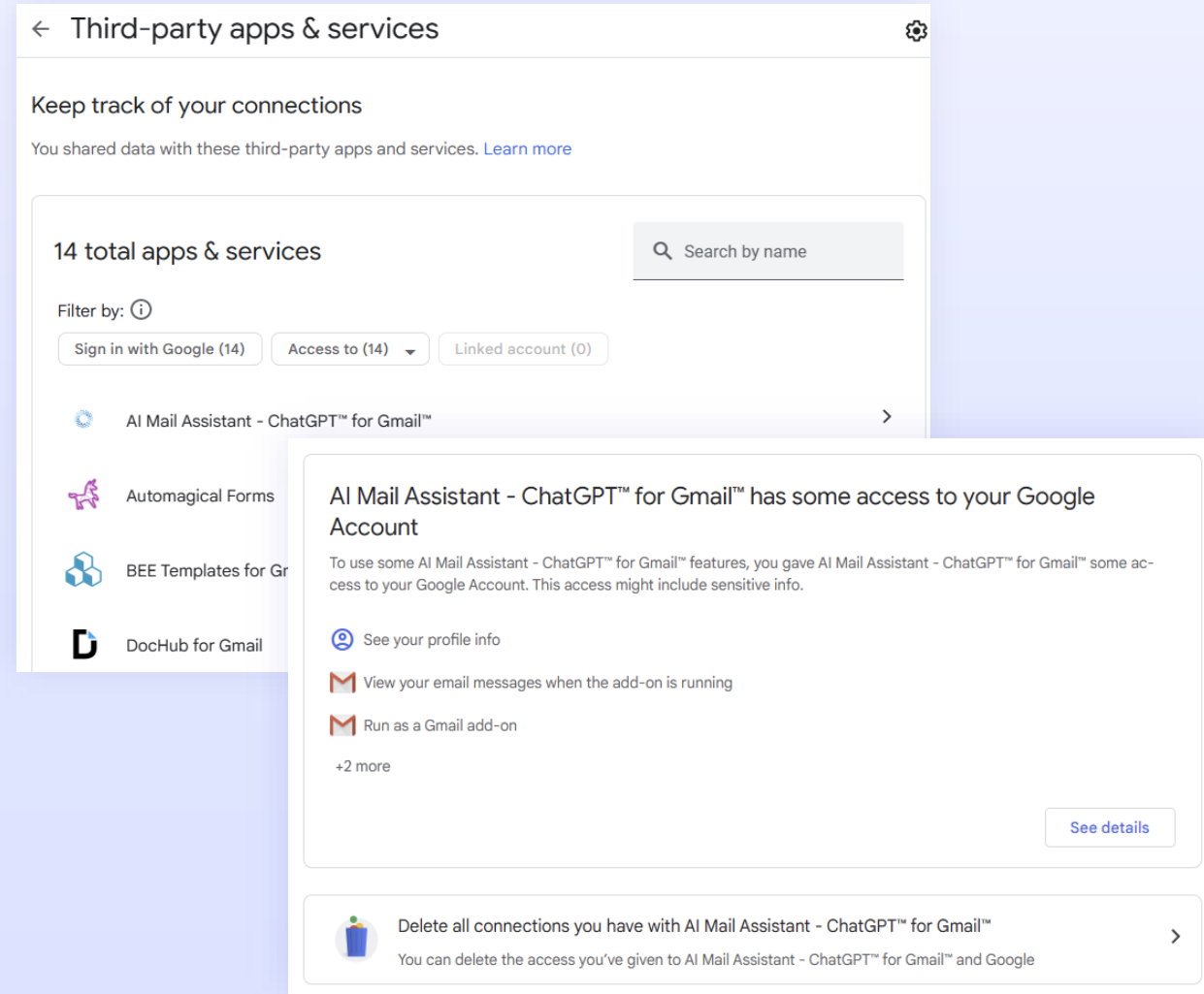
1. Registering for Google Cloud Platform (GCP)
2. Creating a GCP project
3. Setting up the consent screen
4. Retrieve Client ID + Secret



Missing piece #2:

Google's 3rd-Party App Management for users

1. A designated settings page
2. No other place to manage apps
3. Go this page for your own account



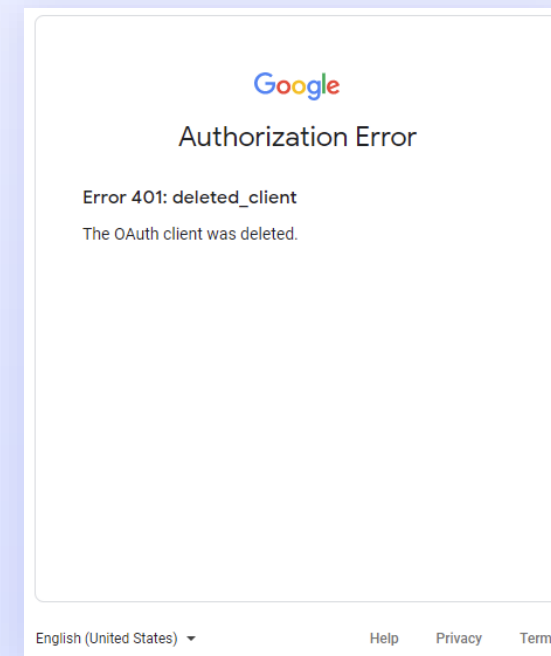


Enter: **The Ghost Token Vulnerability**

App name	Type	ID
515826536802-0cofbgkevtr5mfuq7att53ant...	Web	515826536802-0cofbgkevtr5mfuq7att53...

When a Client ID is deleted:

- Name becomes Client ID
- Client ID cannot be used
- Tokens stopped working
- App disappears from users' management page



**What would happen if we
deleted the GCP project?**

Ghost Token:

Deleting the GCP project



Project is now “Pending Deletion”

- Client ID cannot be used
- Tokens stopped working
- App disappears from users' management page

Shut down project "My GCP Project"

Google Cloud

Resources pending deletion [RESTORE](#)

☐	Name	ID
☐	My GCP Project	projects/my-gcp-project-391107

Project ID *
my-gcp-project-391107

[CANCEL](#) [SHUT DOWN ANYWAY](#)

**What would happen if we
RESTORE project?**



Ghost Token:

Restoring the GCP project



Evil Ann

When project is deleted:
User can't see the app anymore



When project is restored:
The token works again



Ghost Token

 Sign in with Google

Choose an account

to continue to [Totally Innocent App](#)



Victim Account
victim@kohavit.cloud



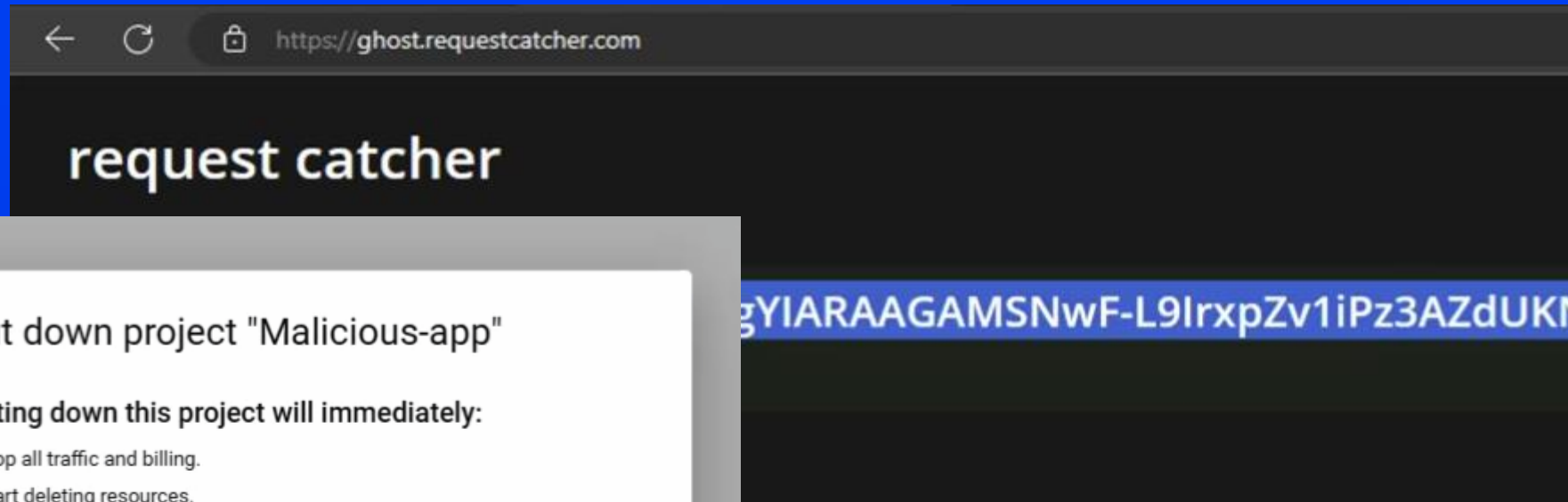
Use another account

English (United States) ▼

[Help](#)

[Privacy](#)

[Terms](#)



Shut down project "Malicious-app"

Shutting down this project will immediately:

- Stop all traffic and billing.
- Start deleting resources.
- Schedule the final deletion of the project after 30 days.
- Block your access to the project.
- Notify the owner of the project.

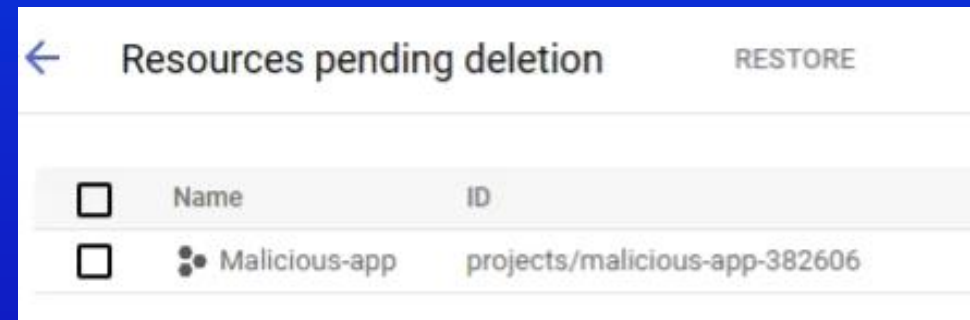
[Learn more about the shutdown process.](#)

To shut down project "Malicious-app", type the project ID: malicious-app-382606

Project ID *

CANCEL

SHUT DOWN ANYWAY



← Apps with access to your account

Third-party apps with account access

You gave these sites and apps access to some of your Google Account data, including info that may be sensitive. Remove access for those you no longer trust or use. [Learn about the risks](#)

 2 of your apps are secured by Cross-Account Protection. [Learn more](#)

	Any.do Gmail Add-on	Has access to Gmail
	CloudConvert	Has access to Google Drive
	Data connector for Zendesk	Has access to Google Docs
	Form Notifications	Has some account access
	Google Analytics	Has access to Google Analytics, Google Docs
	Mergo 	Has access to Gmail, Google Contacts, Google Docs, Google Drive
	Pear Deck	Has access to Google Docs
	Publigo 	Has access to Gmail, Google Docs, Google Drive
	ZIP Extractor	Has access to Google Drive

Resources pending deletion			RESTORE
☐	Name	ID	
☐	Malicious-app	projects/malicious-app-382606	

Shut down project "Malicious-app"

Shutting down this project will immediately:

- Stop all traffic and billing.
- Start deleting resources.
- Schedule the final deletion of the project after 30 days.
- Block your access to the project.
- Notify the owner of the project.

[Learn more about the shutdown process.](#)

To shut down project "Malicious-app", type the project ID: malicious-app-382606

Project ID *

malicious-app-382606

CANCEL

SHUT DOWN ANYWAY

Ghost Token: Takeaways



Ghost Token's threat potential



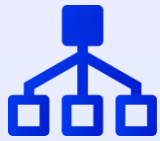
OAuth implementation mistake



Bug hunting heaven



A vision for OAuth 3.0?



Third-party apps
registration
consolidation



User management
and audit of apps



Update OAuth's
protocols

The background is a solid blue color. On the left side, there are several overlapping, semi-transparent blue shapes that resemble stylized letters or abstract forms. On the right side, there is a large, semi-transparent blue shape that resembles a surprised face with wide eyes and an open mouth. The text "Thank you!" is centered in the middle of the image in a white, bold, sans-serif font.

Thank you!